

Модуль 6. Настройка и использование сервиса rsyslog

Auditd

Основным инструментом для сбора системных событий является auditd (сокращение Linux Audit Daemon). Auditd был создан для тесного взаимодействия с ядром ОС – во время своей работы инструмент отслеживает системные вызовы и может записывать события, связанные с файлами ОС (чтение, запись, выполнение, изменение прав). Таким образом, с его помощью можно отслеживать практически любые события, происходящие в операционной системе.

Плюсы auditd:

- работает на низком уровне мониторинга — отслеживает системные вызовы и действия с файлами;
- имеет неплохой набор утилит в комплекте для удобства работы;
- постоянно развивается и обновляется;
- бесплатен и легко устанавливается.

Минусы auditd:

- большинство событий, возникающих при атаках, характерных для конкретного приложения, практически невозможно отслеживать поскольку на уровне системных вызовов и работе с файлами трудно отличить взлом от нормальной работы приложения. Такие события лучше отслеживать на уровне самих приложений;
- auditd может замедлять работу ОС. Это связано с тем, что подсистеме аудита необходимо проводить анализ системных вызовов;
- не слишком гибок в настройке правил;
- на данный момент не лучший инструмент для работы с контейнерами.

Alt-2

Установим пакет audit:

```
# apt-get update && apt-get install audit
```

Запустим и добавим службу auditd в автозагрузку:

```
# systemctl enable --now auditd
```

Файлы конфигурации хранятся в /etc/audit/. Правила желательно хранить в /etc/audit/rules.d/*.rules, по умолчанию доступ к этой директории только у суперпользователя. Обратим внимание на то, что файл с правилами в этой директории должен иметь название *.rules, иначе auditd не прочтает его без явного указания. Если вы решили хранить правила в другом месте, то владелец файла должен быть суперпользователь. Помимо этого рекомендуется выставить группу файла root и права 600, чтобы никто кроме суперпользователя не мог работать с файлом конфигурации auditd, т.к. зная что логируется, атакующий может избежать обнаружения. То же самое касается и файлов с правилами для других инструментов.

Для каждого из регистрируемых событий в журналах указывается следующая информация:

- дата и время;
- субъект, осуществляющий регистрируемое действие;
- тип события (если регистрируется запрос на доступ, то указываются объект и тип доступа);
- успешность осуществления события (обслужен запрос на доступ или нет).

Правила для логирования можно добавлять следующими способами:

1. Записать его в файл(ы) `/etc/audit/rules.d/<имя файла>.rules` и перезапустить сервис.
2. Записать в файл по произвольному пути и указать его явно с помощью утилиты `auditctl` с опцией `-R`.
3. Добавить правило также можно с помощью утилиты `auditctl` с опцией `-a`.

Для просмотра журналов используются команды `ausearch` и `aureport`.

Создадим файл `/etc/audit/rules.d/audit.rules`:

```
[root@alt2 ~]# cat /etc/audit/rules.d/audit.rules
-a always,exit -F arch=b64 -S fchmod -S fchmodat -S fchown -S fchownat -F dir=/srv/share -k share_access
```

`-a [list,action],[action,list]` добавляет правило в конец списка правил.

Основные варианты списков:

`exit` добавляет правило к списку, отвечающему за точки выхода из системных вызовов. Список применяется, когда необходимо создать событие для аудита, привязанное к точкам выхода из системных вызовов.

`exclude` добавляет правило к списку, отвечающего за фильтрацию событий определенного типа. Список используется, чтобы отфильтровывать ненужные события.

Варианты действий:

`always` устанавливает контекст аудита. Всегда заполнять его во время входа в системный вызов и всегда генерировать запись во время выхода из системного вызова;

`never` не генерирует никаких записей.

`-F [n=v | n!=v | n<v | n>v | n<=v | n>=v | n&v | n&=v]` задает поле сравнения для правила. Атрибуты поля следующие: объект, операция, значение. Таким образом можно задать до 64 полей сравнения в одной команде. Каждое новое поле должно начинаться с `-F`. Аудит будет генерировать запись, если произошло совпадение по всем полям сравнения. Допустимо использование таких операторов как «равно», «не равно», «меньше», «больше» и т.д.

Параметр `arch=b64`:

Т.к. система ориентируется на номера (не названия) системных вызовов, а для многих системных вызовов номера отличаются для 32 и 64 разрядных систем, то необходимо указывать для какой архитектуры мы пишем правило.

Описание указанного выше правила:

Правило отслеживает, когда открываются, изменяются права или владельцы файлов в папке `/srv/share`.

Во всех правилах используется ключ для удобного поиска в логах.

Чтобы загрузить правила из каталога `/etc/audit/rules.d/` необходимо выполнить команду:

```
# augenrules --load
```

Проверим работу правила:

Изменим права доступа к папке `/srv/share`:

```
# chmod 777 /srv/share
```

Выполним поиск файла:

```
# ausearch -k share_access
```

или

```
# cat /var/log/audit/audit.log | grep share_access
```

Rsyslog

События, зафиксированные с помощью *auditd*, можно передавать в *rsyslog* для дальнейшей обработки, фильтрации и отправки на сервер.

Установим пакет *rsyslog* как на сервере, так и на клиенте:

```
# apt-get update && apt-get install rsyslog
```

Запустим и добавим в автозагрузку *rsyslog*:

```
# systemctl enable --now rsyslog
```

Основным конфигурационным файлом *rsyslog* является `/etc/rsyslog.conf`. В нем подключены все файлы из папки `/etc/rsyslog.d/` с помощью директивы *include* в самом начале файла:

```
# cat /etc/rsyslog.conf
```

В этих файлах могут содержаться дополнительные настройки, например, аутентификация на *rsyslog* сервере.

Главный конфигурационный файл обеспечивает управление локальными логами по умолчанию, но для работы через сеть нужно добавить настройки.

Синтаксис конфигурационного файла:

\$переменная значение

Все директивы начинаются со знака доллара, содержат имя переменной, а дальше связанное с ней значение. Так выглядит каждая строка конфигурационного файла. В его первой части размещены общие настройки программы и загрузка модулей, во второй – правила сортировки и фильтрации лог-файлов.

Отредактируем конфигурационный файл `/etc/rsyslog.conf` на хосте *alt-2*:

```
# vim /etc/rsyslog.conf
```

```
include(file="/etc/rsyslog.d/*.conf" mode="optional")
$ModLoad imfile
$InputFileName /var/log/audit/audit.log
$InputFileStateFile audit_log
$InputFileTag audit_log
$InputFileFacility local6
$InputFileSeverity info
$InputRunFileMonitor

local6.info @@192.168.10.10:514

$ModLoad imudp
$UDPServerRun 514

$ModLoad imtcp
$InputTCPServerRun 514
```

Разберем основные части конфигурационного файла */etc/rsyslog.conf*:

\$ModLoad imfile

Загружает модуль *imfile*, который позволяет *rsyslog* читать и обрабатывать содержимое файлов. Без этого модуля *rsyslog* не сможет отслеживать изменения в указанных файлах.

\$InputFileName /var/log/audit/audit.log

Указывает путь к файлу, который будет отслеживаться. В данном случае это файл журнала аудита. Основной файл, который *rsyslog* будет мониторить на наличие новых записей.

\$InputFileStateFile audit_log

Указывает имя файла состояния для отслеживаемого файла. Данный файл хранит информацию о том, где *rsyslog* остановился при последнем чтении, чтобы избежать повторного считывания уже обработанных данных. Так *rsyslog* эффективно обрабатывает новые записи, не теряя или не дублируя их.

\$InputFileTag audit_log

Задаёт тег для записей, которые будут созданы из этого файла. Тег добавляется к каждой записи, чтобы идентифицировать источник. Так удобнее фильтровать и идентифицировать логи при их обработке или отправке.

\$InputFileFacility local6

Указывает уровень службы (facility), к которой будут относиться логи из этого файла. В данном случае используется *local6*, который обычно резервируется для пользовательских приложений.

\$InputFileSeverity info

Указывает уровень важности (severity) логов, создаваемых из этого файла. В данном случае используется уровень *info*. Уровни важности помогают фильтровать логи по критичности.

\$InputRunFileMonitor

Запускает мониторинг файла */var/log/audit/audit.log* с учетом всех предыдущих настроек. Фактически активирует все настройки, сделанные ранее для мониторинга файла.

Для определения набора правил для обработки удаленных логов необходим следующий формат:

facility.severity_level destination (where to store log)

где:

facility – тип сообщения о процессе/приложении, к которому относятся *auth*, *cron*, *daemon*, *kernel*, *local0..local7*. Использование * означает все объекты.

severity_level – тип сообщения журнала: *out-0, alert-1, crit-2, err-3, warn-4, notice-5, info-6, debug-7*. Использование * означает все уровни *severity*, а *none* означает ни одного уровня *severity*.

destination – локальный файл, либо удаленный сервер *rsyslog* в формате *IP:port*.

`local6.info @@192.168.10.10:514`

Указывает, что все логи с тегом *local6* и уровнем важности *info* должны быть отправлены на удаленный сервер по адресу 192.168.10.10 через UDP.

`$ModLoad imudp`

Загружает модуль *imudp*, который обрабатывает все входящие сообщения по протоколу *UDP*.

`$UDPServerRun 514`

Настраивает входящий *UDP*-порт для получения логов.

По умолчанию используется порт 514.

`$ModLoad imtcp`

Загружает модуль *imtcp*, который обрабатывает все входящие сообщения по протоколу *TCP*.

`$InputTCPServerRun 514`

Настраивает входящий *TCP*-порт для получения логов.

По умолчанию используется порт 514.

После редактирования файла */etc/rsyslog.conf* перезапускаем *rsyslog*:

`# systemctl restart rsyslog`

Зайдем в учетную запись суперпользователя на хосте *alt-1*.

Отредактируем конфигурационный файл */etc/rsyslog.conf*:

`# vim /etc/rsyslog.conf`

```
include(file="/etc/rsyslog.d/*.conf" mode="optional")
$ModLoad imudp
$UDPServerRun 514

$ModLoad imtcp
$InputTCPServerRun 514

$template RemoteLogs, "/var/log/remote_audit.log"
*. * ?RemoteLogs
& ~
```

Разберем основные части конфигурационного файла */etc/rsyslog.conf*:

`$template RemoteLogs, "/var/log/remote_audit.log"`

Директива *\$template* используется для определения нового шаблона формата для записи логов. В данном случае создается шаблон с именем *RemoteLogs*. Имя шаблона *RemoteLogs* будет использоваться в последующих строках конфигурации.

`*.* ?RemoteLogs`

`*.*` – правило фильтрации, которое указывает, что будут обрабатываться все сообщения (все уровни важности и все уровни служб). Первая звездочка (*) соответствует любому уровню службы *facility*, а вторая звездочка (*) — любому уровню важности *severity*.

`?RemoteLogs` указывает, что сообщения, соответствующие этому правилу, должны быть записаны с использованием шаблона *RemoteLogs*, который мы определили ранее. Т.е. все логи будут записаны в файл */var/log/remote_audit.log*.

`& ~`

Символ & используется для указания того, что обработка сообщения должна быть завершена после выполнения предыдущего правила. Т.е. сообщение не будет отправлено дальше по другим правилам конфигурации.

Символ ~ указывает на то, что сообщение должно быть отброшено после его обработки. Таким образом, после того как сообщение будет записано в файл `/var/log/remote_audit.log`, оно не будет обрабатываться другими правилами.

После редактирования файла `/etc/rsyslog.conf` перезапускаем rsyslog:

```
# systemctl restart rsyslog
```

Важно! Проверьте, что порты 514 открыты и на сервере, и на клиенте:

```
# netstat -pnltu
```

```
[root@alt-1 ~]# netstat -pnltu
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:514            0.0.0.0:*               LISTEN      28941/rsyslogd
tcp        0      0 :::514                 :::*                     LISTEN      28941/rsyslogd
tcp        0      0 :::631                  :::*                     LISTEN      1/init
udp        0      0 0.0.0.0:37314          0.0.0.0:*               2677/avahi-daemon:
udp        0      0 0.0.0.0:514            0.0.0.0:*               28941/rsyslogd
udp        0      0 0.0.0.0:631            0.0.0.0:*               2990/cups-browsed
udp        0      0 0.0.0.0:5353            0.0.0.0:*               2677/avahi-daemon:
udp        0      0 127.0.0.1:323          0.0.0.0:*               2719/chronyd
udp        0      0 :::39406                :::*                     2677/avahi-daemon:
udp        0      0 :::514                  :::*                     28941/rsyslogd
udp        0      0 :::5353                  :::*                     2677/avahi-daemon:
udp        0      0 :::1:323                 :::*                     2719/chronyd

[root@alt-2 ~]# netstat -pnltu
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:514            0.0.0.0:*               LISTEN      28527/rsyslogd
tcp        0      0 :::631                  :::*                     LISTEN      1/init
tcp        0      0 :::514                  :::*                     LISTEN      28527/rsyslogd
udp        0      0 0.0.0.0:5353            0.0.0.0:*               2319/avahi-daemon:
udp        0      0 0.0.0.0:39746           0.0.0.0:*               2319/avahi-daemon:
udp        0      0 127.0.0.1:323          0.0.0.0:*               2361/chronyd
udp        0      0 0.0.0.0:514            0.0.0.0:*               28527/rsyslogd
udp        0      0 0.0.0.0:631            0.0.0.0:*               2702/cups-browsed
udp        0      0 :::5353                  :::*                     2319/avahi-daemon:
udp        0      0 :::1:323                 :::*                     2361/chronyd
udp        0      0 :::59824                 :::*                     2319/avahi-daemon:
udp        0      0 :::514                  :::*                     28527/rsyslogd
```

Утилита `netstat` показывает сетевые соединения, таблицы маршрутизации, статистику интерфейсов и другую информацию о сетевых соединениях.

Опция `-p` (`--program`) показывает идентификатор процесса (PID) и имя программы, которая использует каждое соединение или прослушиваемый порт.

Опция `-n` (`--numeric`) выводит адреса и порты в числовом формате. Таким образом вместо разрешения имен хостов и сервисов будет отображаться IP-адрес и номер порта.

Опция `-l` (`--listening`) ограничивает вывод только теми соединениями, которые находятся в состоянии "прослушивания". Т.е. в выводе будут только те порты, которые ожидают входящих соединений.

Опция `-t` (`--tcp`) отображает только TCP-соединения, а опция `-u` (или `--udp`) – UDP-соединения.

Проверим настройку `rsyslog`.

На хосте `alt-1` запустим команду для отслеживания изменений в файле `/var/log/remote_audit.log`:

```
# tail -f /var/log/remote_audit.log
```

На хосте `alt-2` отправим запросы к сайту `ya.ru`:

```
# chmod 777 /srv/share
```

В результате в файле `/var/log/remote_audit.log` должны появиться записи.